**Course Code: ITA1439** **Course Name: Ethical Hacking** **Slot: A**

**CO1 – ASSIGNMENT_1**

**Nature of Assignment: Individual** **Duration: 1 Week** **Total Marks: 50**

| **Student Name** | **Reg. No** |
|---|---|
| BP Venkata Uday Kumar | 192411203 |

**CO1:** Apply the foundational concepts of ethical hacking, including the types of hackers, ethical principles, legal frameworks, and the role of responsible disclosure in cybersecurity.

**Assignment Title:** Design and Develop a Complete Ethical-Hacking Engagement Framework for a University's Authorized Security-Assessment Programme.

## Scenario - University Authorized Security-Assessment Programme:

A university is establishing an Authorized Security-Assessment Programme to test the security of its student portal, learning-management system, email service and campus network before a major upgrade. The programme must cover approximately 20 systems and 50 staff initially, but the framework is expected to remain usable as the programme grows to the whole university and begins to include external, third-party assessors.

The management has not yet fixed how ethical-hacking engagements will be governed. Testing may be requested by different departments, carried out by internal staff or external testers, and may touch systems that hold personal data. The team is concerned that an unstructured approach may lead to unauthorized access, legal exposure, damage to live systems, unclear scope or uncoordinated disclosure of discovered vulnerabilities.

You have been appointed as the Ethical-Hacking Governance Team. Your responsibility is not merely to describe hacking tools. You must investigate the requirements, design a complete engagement framework, construct reusable components and documents, integrate the different parts, validate the design through a walkthrough and defend the final framework using evidence.

The final framework must clearly distinguish between what is authorized, what is legal, and what is appropriate for the university. The team is expected to make governance decisions independently and justify why the framework is suitable for the given scenario. No live exploitation is performed; all work stays at the design, documentation and isolated-lab level.

**UASAP-EF: University Authorized Security-Assessment Programme – Engagement Framework**

## How this document is organised

The framework is called **UASAP-EF**. Tasks 1 to 11 of the assignment are answered in order, and each task ends with the evidence the task asks for. Five principles were followed throughout:

- **Design level only.** No live exploitation is performed. All hands-on work is described for the isolated lab (192.168.56.0/24); the 20 university systems are fictional register entries with private example addresses.
- **Evidence is reproducible.** The authorization, finding and disclosure rules were implemented as a small Python reference program (Appendix A). Every test result in Tasks 8, 9 and 11 was produced by running that program, and every number in Tasks 10 and 11 was produced by a seeded simulation, not typed by hand.
- **Model parameters are assumptions.** The simulation uses stated assumptions (arrival rates, review times). They show how the design behaves and must be replaced by measured values once the programme is running.
- **Authorized, legal and appropriate are three separate tests.** An action must have written authorization (permission), comply with law (legality) and be consistent with university policy and ethics (appropriateness). Passing one test never substitutes for the others.
- **Dates.** Legal position is stated as on 2 November 2026. The legal mapping is an academic analysis and not legal advice.

| Version | Stage | What changed |
|---|---|---|
| v1.0 | Tasks 1–8 | Baseline design: central review of every request, manual scope checking, central disclosure triage. |
| v1.1 | Task 9 | Five defects found by the walkthrough tests were corrected (F1–F5). |
| v1.2 | Task 10 | Governance refined from scalability results: risk-tiered approval, register-based scope lookup, disclosure routing. |
| v2.0 | Task 11 | Revised for continuous and third-party assessments: standing authorizations, data-protection gate, disclosure clock, assessor onboarding. |

## TASK 1 – Formulate the Enquiry and Framework Blueprint (4 Marks)

## 1.1 Systems in scope

The scenario names four service areas (student portal, learning-management system, email service and campus network) and about 20 systems. The 20 systems were fixed as the following register, and the register itself becomes the single source of truth for scope.

| Group | Register IDs | Systems | Count | Holds personal data |
|---|---|---|---|---|
| Student portal | SYS-01 to SYS-03 | Web front end, application server, database | 3 | Yes (all) |
| Learningmanagement system | SYS-04 to SYS-07 | Web, application server, database, file store | 4 | Yes (all) |
| Email service | SYS-08 to SYS-10 | Mail gateway, mailbox store, webmail | 3 | Yes (all) |
| Campus network | SYS-11 to SYS-16 | Core switch, distribution switches, Wi-Fi controller, perimeter firewall, VPN gateway, DNS/DHCP | 6 | Only SYS-15 (VPN user identities) |
| Supporting services | SYS-17 to SYS-20 | SSO/identity, backup server, log/SIEM server, admin jump host | 4 | SYS-17, 18, 19 yes; SYS-20 no |
| **Total** | | | **20** | **14 of 20 hold personal data** |

## 1.2 Stakeholders

| Stakeholder | Role in the framework |
|---|---|
| Governance Board (GB) | Owns the framework; approves high-risk engagements; decides escalations and any full-disclosure request. |
| Programme Owner (CISO) | Runs the programme day to day; chairs the GB; keeps the scope register and the engagement log. |
| Department Authoriser (DA) | Head of the requesting department; approves low-risk engagements (introduced in v1.2). |
| System Owner | Owns each system in the register; signs that the system may be tested and receives findings. |
| Lead Tester (internal or external) | Plans and performs the testing within the RoE; writes the finding reports. |

| | |
|---|---|
| Data Protection Officer (DPO) | Reviews any engagement touching personal data; receives personal-data findings within 24 hours. |
| **Stakeholder** | **Role in the framework** |
| Legal Counsel | Confirms legal basis, contracts (NDA, data-processing agreement) and any law-enforcement contact. |
| Disclosure Coordinator (DC) | Triages findings, tracks remediation windows and runs the disclosure process. |
| Lab Custodian | Builds, records and resets the isolated lab. |
| Students and staff | Data subjects whose information must not be exposed by testing. |
| External parties | Third-party assessors, software vendors, CERT-In and other regulators. |

## 1.3 Expected activities and constraints

**Expected activities:** asset discovery against the register; vulnerability scanning; configuration and patch review; web-application assessment (on a lab replica); password-policy and access-control review; reporting; remediation re-test; responsible disclosure. **Excluded activities:** denial-of-service, phishing of students or staff, physical intrusion and any use of real personal data in a test.

**Constraints:** (C1) no live exploitation in this exercise; (C2) live systems must stay available, especially during admissions and examinations; (C3) 14 of the 20 systems hold personal data; (C4) the framework starts with about 20 systems and 50 staff but must scale to the whole university; (C5) external assessors will join later; (C6) Indian law applies, and some foreign law may apply to foreign testers or cloud assets; (C7) approval staff are few, so the process must not become a bottleneck.

## 1.4 Engagement-governance requirements

| ID | Requirement (the framework must…) | Scenario source | Answered in |
|---|---|---|---|
| R1 | obtain written authorization from a named authority before any test activity | “unauthorized access” | Tasks 5, 6, 8 |
| R2 | define scope explicitly and treat everything not listed as out of scope | “unclear scope” | Task 5 |
| R3 | set rules of engagement: windows, permitted and prohibited techniques, escalation | “damage to live systems” | Task 5 |
| R4 | map each engagement to the relevant law and tie each legal duty to a control | “legal exposure” | Task 4 |

| | | | |
|---|---|---|---|
| R5 | protect personal data during testing and in reports | “systems that hold personal data” | Tasks 3, 4, 8 |
| R6 | model the attackers the university actually faces and classify them consistently | types of hackers | Task 2 |
| R7 | bind testers to a code of conduct with stop-rules | ethical principles | Task 3 |
| **ID** | **Requirement (the framework must…)** | **Scenario source** | **Answered in** |
| R8 | keep hands-on testing in an isolated lab | “isolated-lab level” | Task 7 |
| R9 | record findings in a structured, confidential report | reusable documents | Task 8 |
| R10 | disclose vulnerabilities responsibly with a timeline | “uncoordinated disclosure” | Task 6 |
| R11 | scale from one department to the whole university and external assessors | “remain usable as the programme grows” | Tasks 10, 11 |
| R12 | keep an auditable record of approvals, actions and decisions | “defend… using evidence” | Tasks 6, 8, 9 |

## 1.5 Framework blueprint

Figure 1 shows how the components cooperate. The five boxes in the middle are the engagement lifecycle. Each hand-over between two boxes is a **gate**: the next stage cannot start until the gate check passes and its result is written to the engagement log. The threat model, ethics module and legal map are not stages. They feed rules into the gates, so that no document or rule stands alone.

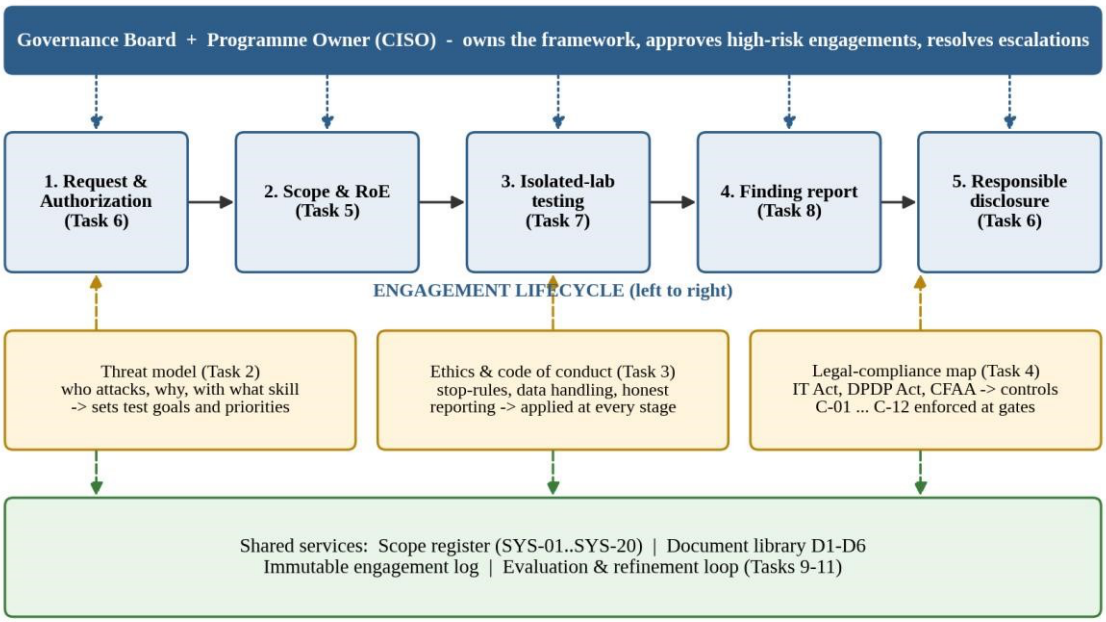



*Figure 1: UASAP-EF blueprint – lifecycle, cross-cutting modules and shared services*

| **Gate** | **Between** | **Checks performed** | **Components that supply the checks** |
|---|---|---|---|
| G1 Authorization | Request → Scope & RoE | Signed D1 form; signatory authority; dates; personal-data and contract checks | Task 6 workflow; Task 4 controls C-01, C-05, C-06 |
| **Gate** | **Between** | **Checks performed** | **Components that supply the checks** |
| G2 Preengagement | RoE → Lab testing | Pre-engagement checklist (Task 5); conflict-of-interest declaration; tool allow-list | Task 5 RoE; Task 3 checks CK1, CK3, CK7 |
| G3 Lab | Lab testing → Report | Lab verified isolated; targets inside allow-list; activity log complete | Task 7 operations; Task 3 check CK2 |
| G4 Reporting | Report → Disclosure | Finding in scope, inside window, severity consistent, evidence redacted | Task 8 D3 validation; Task 4 control C-09 |
| G5 Disclosure | Disclosure → Closure | Track chosen; DPO informed; remediation window; release decision | Task 6 disclosure rules; Task 4 controls C-10, C-11 |

## 1.6 Enquiry questions the framework must answer

| ID | Enquiry question | Short answer given by the framework | Task |
|---|---|---|---|
| Q1 | Who authorizes a test, and how is the authorization recorded and verified? | The owner of every system in scope signs form D1; the GB or DA approves by risk tier; the record (AUTH-ID) is verified by rules AV1–AV9. | 5, 6 |
| Q2 | What is in scope, and how is an out-of-scope request detected? | Only register IDs named in the scope list; everything else is denied by default and caught by rules OS1–OS5. | 5 |
| Q3 | Which laws apply, especially when personal data is touched? | IT Act 2000 (ss. 43, 66, 72, 72A, 43A), DPDP Act 2023 as a design standard, CERTIn directions; CFAA where a US element exists. | 4 |
| Q4 | Which attackers must we defend against and how are they classified? | Eight actor types classified on four axes with a fixed rule order. | 2 |
| Q5 | How are findings disclosed, when, and who decides? | Coordinated disclosure with severity-based windows; the GB alone can approve full disclosure. | 6 |
| Q6 | How is hands-on testing contained and kept authorized? | Host-only lab 192.168.56.0/24 with no route outside, an allow-list scope guard and a lab record. | 7 |
| Q7 | Does the framework still work at ten times the size, and with external assessors? | Yes after refinement: measured in Task 10 and re-checked in Task 11. | 10, 11 |

## 1.7 Design criteria used as acceptance criteria

| ID | Design criterion | Measurable acceptance test | Verified in |
|---|---|---|---|
| DC1 | Authorization completeness | No engagement activity is accepted without a signed, in-date D1 form (tests T1, L5). | Tasks 8, 9 |
| DC2 | Scope containment | Zero out-of-scope targets or findings accepted (tests T2, L6, L14). | Tasks 8, 9 |
| DC3 | Legal traceability | Every legal requirement in the Task 4 table is linked to at least one control ID. | Task 4 |
| DC4 | Personal-data protection | No finding with un-redacted personal data is accepted (L13); personal-data findings are never released publicly (T5). | Tasks 8, 9 |

| | | | |
|---|---|---|---|
| DC5 | Timeliness at scale | At least 95 % of approvals complete within 40 working hours in the large programme. | Task 10 |
| DC6 | Disclosure safety | Critical and High findings reach the owner within 8 working hours; no automatic public disclosure. | Tasks 9, 10, 11 |
| DC7 | Extensibility | A new assessor type or rule change touches at most one component plus the document library. | Task 11 |

### 1.8 Rationale

The scenario fails if any one control is missing: a test with perfect scope but no signed authorization is still unauthorized access; a signed authorization that ignores personal data still creates legal exposure; and a finding that is correct but disclosed carelessly can itself leak data. For this reason the framework is built as a chain of gates in which each stage consumes the structured output of the previous one (scope IDs, authorization ID, personal-data flag, severity). The cross-cutting modules are expressed as rules and controls rather than as essays, so they can be tested. The requirements R1–R12 are each assigned to a task, and the seven design criteria are re-checked at the end of Task 11, so the framework is judged against the criteria set here and not against criteria chosen afterwards.

**Evidence delivered for Task 1:** requirements table (1.4), blueprint (Figure 1 and gate table), seven enquiry questions (1.6), seven design criteria (1.7) and the rationale (1.8).

## TASK 2 – Design a Hacker Threat Model and Classification (4 Marks)

### 2.1 Classification axes and naming

Names such as “grey-hat” are used loosely in the industry, so the framework classifies an actor on four independent axes first and derives the type from the axes. This makes two analysts reach the same answer.

| Axis | Values | Code |
|---|---|---|
| A – Authorization | Valid written authorization covering the action / none | AUTH / UNAUTH |
| P – Position | Holds university credentials or physical access (Internal) / does not (External) | INT / EXT |
| I – Intent | Protect (PRO); curiosity or recognition (CUR); financial gain (FIN); ideology or publicity (IDE); strategic or espionage (STR); malicious or revenge (MAL); negligence (NEG) | PRO, CUR, FIN, IDE, STR, MAL, NEG |
| C – Capability | L1 uses ready-made tools without understanding; L2 adapts public exploits; L3 writes custom tools or runs a planned social-engineering campaign; L4 sustained, well-resourced, may use unknown vulnerabilities | L1–L4 |

**Naming convention:** <Authorization>-<Position>-<Intent>-<Capability>. For example, UNAUTHEXT-FIN-L3 is an external criminal with custom tools; AUTH-INT-PRO-L2 is an internal authorized tester.

## 2.2 Classification rules (applied in this order, first match wins)

| Rule | Condition | Resulting type |
|---|---|---|
| CR1 | A = AUTH for the exact action, target and time | **White-hat** (authorized tester) |
| CR2 | Not CR1; I = STR, C = L4 and the activity is directed or funded by a state body | **State-sponsored actor** |
| CR3 | Not CR1–CR2; P = INT and I is MAL, FIN or NEG (misuses or mishandles legitimate access) | **Insider** (malicious or negligent) |
| CR4 | Not CR1–CR3; I = IDE (cause, publicity, protest) | **Hacktivist** |
| CR5 | Not CR1–CR4; I = FIN or MAL and C ≥ L2 | **Black-hat** |
| CR6 | Not CR1–CR5; C = L1 and I = CUR with no understanding of the tools used | **Script kiddie** |
| CR7 | Not CR1–CR6; UNAUTH, no intent to harm or profit, and the actor discloses or is willing to disclose | **Grey-hat** |

The rule order matters: authorization is tested first because it is the only factor that separates a whitehat from every other type, and intent-to-harm is tested before curiosity so that a harmful actor cannot be downgraded to “curious”. If more than one of CR3–CR7 seems to match, the analyst records the alternatives and selects the final type by the scoring table described in 2.4.

## 2.3 Threat model: type, motivation, capability and likely university targets

| Type | Example code | Motivation | Typical capability | Likely targets in the university |
|---|---|---|---|---|
| White-hat | AUTH-INT-PROL2 / AUTH-EXT-PRO-L3 | Improve security; professional duty or contract | L2–L3 | Only systems named in the signed scope (e.g. SYS-04 to SYS-07) |
| Black-hat | UNAUTH-EXT-FIN-L3 | Money: ransom, sale of data, fraud | L2–L3 | Student portal database (SYS-03), mailboxes (SYS-09), backup server (SYS-18), phishing of staff |

| | | | | |
|---|---|---|---|---|
| Grey-hat | UNAUTH-EXT-CUR-L2 / UNAUTH-INTCUR-L2 | Curiosity, reputation, hope of reward; no intent to harm | L2–L3 | LMS web (SYS-04), portal endpoints (SYS-01), exposed services found by scanning |
| Script kiddie | UNAUTH-EXT-CUR-L1 | Fun, bragging, peer status | L1 | Public web pages, webmail login (SYS-10), Wi-Fi (SYS-13) |
| Hacktivist | UNAUTH-EXT-IDE-L2 | A cause: fees, policy, politics; publicity | L1–L3 | Website defacement, denial of service, leaking internal documents |
| Malicious insider | UNAUTH-INTMAL-L2 | Grievance, grade tampering, money | L1–L3 plus privileged access | LMS grades (SYS-06), student database (SYS-03), SSO (SYS-17) |
| Negligent insider | UNAUTH-INTNEG-L1 | None (mistakes, weak passwords, misconfiguration) | L1 | File store (SYS-07), mailboxes, admin jump host (SYS-20) |
| Statesponsored | UNAUTH-EXT-STR-L4 | Espionage on research and staff communications | L4 | Research data, faculty mail, VPN (SYS-15), SSO (SYS-17) |

**Use of the model:** targets with several threat types attached (SSO, student database, mailboxes) are given first priority in the engagement schedule, and the technique list in the RoE is limited to what is needed to emulate the relevant actor at the relevant capability level (L1–L3). L4 actors are modelled by analysis only, never by emulation.

## 2.4 Borderline actor: two or more ways to classify

**Actor X.** A final-year student, from a campus lab computer, runs a vulnerability scanner against the LMS using her own student login. She finds that an export link returns grade lists, downloads 40 records “to prove it” and e-mails the IT helpdesk the next day.

| **Criterion (facts about Actor X)** | **Alt. 1: Malicious insider (CR3)** | **Alt. 2: Black-hat (CR5)** | **Alt. 3: Grey-hat (CR7)** |
|---|---|---|---|
| No written authorization (UNAUTH) | Match | Match | Match |
| Has legitimate student credentials (INT) | Match | No match (needs external) | Compatible |
| Intent to harm, profit or tamper | Needs MAL/FIN: **No match** | Needs FIN/MAL: **No match** | No intent: **Match** |

| | | | |
|---|---|---|---|
| Capability L2 (public scanner, one export URL) | Compatible | Match (L ≥ 2) | Match |
| Disclosed the issue herself within one day | Contradicts (insiders conceal) | Contradicts (criminals conceal) | **Match** (CR7) |
| Personal data copied (40 records) | Match | Match | Compatible (aggravating, but not intent) |
| **Score (criteria matched or compatible out of 6)** | **3 of 6** | **3 of 6** | **6 of 6** |

**Why Alternatives 1 and 2 were rejected.** Both rest on the unauthorized access and the copied data, but both require an intent to harm or to profit, and the facts show none. Both would also predict concealment, whereas Actor X reported. Classifying her as a criminal would push the university to a punitive response that discourages the next student from reporting.

**Final classification: Grey-hat, code UNAUTH-INT-CUR-L2, flagged "personal data copied".** Position is recorded as INT, so the insider channel is also reviewed. **Response consequence:** the incident is handled on a restorative path (ask her to delete the copy and confirm in writing, fix the export URL at once, notify the DPO because 40 student records were copied, refer the conduct issue to the proper committee, and offer a route to join the programme as an authorized tester). **Limit of the classification:** the label does not make the act lawful. Under IT Act s. 43(a)–(b) the access and copying are still unauthorized, which is exactly why Task 6 exists.

**Evidence delivered for Task 2:** axes and naming (2.1), rule-ordered criteria (2.2), mapping table (2.3), two rejected alternatives with scoring and the justified final classification (2.4).

## TASK 3 – Create an Ethics and Code-of-Conduct Module (4 Marks) 3.1 Ethical principles of an authorized engagement

| ID | Principle | What must be true in practice |
|---|---|---|
| EP1 | Written authorization | No activity starts until a valid AUTH-ID exists and its dates cover the activity. |
| EP2 | Agreed scope | Every target is on the scope list; anything unlisted is out of scope. |
| EP3 | Confidentiality | Findings and any data seen are shared only with named recipients, stored encrypted and never discussed outside the programme. |
| EP4 | Integrity | Testers do not alter or delete production data or logs; evidence is hashed when recorded. |
| EP5 | Avoid harm | Low-impact techniques, agreed windows, no denial-ofservice; stop at the first sign of instability. |

| | | |
|---|---|---|
| EP6 | Honest reporting | All findings are reported, including the tester's own mistakes; severity is not inflated or hidden. |
| EP7 | Privacy and data minimisation | Real personal data is never copied; if exposed, the tester stops and reports. |
| EP8 | Competence and independence | Testers use only techniques they are competent in and declare any conflict of interest. |
| EP9 | Responsible disclosure | Vulnerabilities are released only through the disclosure process of Task 6. |

### 3.2 Rules and checks that prevent or detect unethical action

| ID | Check | Type | Trigger and action |
|---|---|---|---|
| CK1 | Pre-flight authorization check | Preventive | Before each session the tester enters the AUTH-ID; the Lead Tester confirms it is ACTIVE and in date (rules AV1–AV9). No ID, no session. |
| CK2 | Scope guard | Preventive | A wrapper script compares every target with the allow-list and refuses anything else (Task 7, scope_check.sh). |
| CK3 | Tool allow-list | Preventive | Only tools named in the RoE may be used; password-cracking and exploitation frameworks are limited to the lab. |
| CK4 | Stop conditions | Corrective | Stop at once and escalate if: unexpected personal data appears, a system becomes unstable, scope is unclear, or signs of a real intruder are seen. |
| CK5 | Two-person rule | Preventive | Any test on a production system needs a second named person on standby (the System Owner's delegate). |
| **ID** | **Check** | **Type** | **Trigger and action** |
| CK6 | Activity-log review | Detective | The Programme Owner compares the activity log with the RoE every week; any entry outside scope, window or technique list is a deviation. |
| CK7 | Conflict-of-interest declaration | Preventive | Tester declares any link with the system owner, vendor or a student in scope; the GB decides. |
| CK8 | Evidence redaction check | Preventive | A reviewer confirms that screenshots and logs contain no real personal data before a report is accepted (rule D3 in Task 8). |

### 3.3 Decision rules

Each action is described by four facts: authorization valid (Y/N), target in scope (Y/N/?), technique permitted (Y/N/?) and personal data touched (Y/N). The rules are applied in order:

| Rule | IF … | THEN … |
|---|---|---|
| DR1 | authorization = N, or scope = N, or technique prohibited | **STOP** and record an incident. The action is unacceptable. |
| DR2 | any of scope, technique is "?" (unclear) | **PAUSE.** Ask the Lead Tester and System Owner in writing. Continue only after a written "yes". |
| DR3 | personal data touched = Y | **PAUSE.** Do not copy the data; report to the DPO within 24 hours; continue only with redaction. |
| DR4 | all facts are Y/Y/permitted and no personal data | **PROCEED** and log the action. |
| DR5 | a tester reports their own mistake | Record it, correct it and do not punish honest reporting (just-culture rule). |

### 3.4 Scenario cases and the module's response

| Case | Situation | Auth / Scope / Technique / PD | Rule applied | Response |
|---|---|---|---|---|
| A1 | Authorized port scan of SYS-04 in the agreed window, using an allowed tool. | Y / Y / Y / N | DR4 | **Acceptable – PROCEED**, logged. |
| A2 | Weak TLS version noticed on SYS-08; only the protocol version is recorded and reported in D3. | Y / Y / Y / N | DR4 | **Acceptable – PROCEED**. |
| **Case** | **Situation** | **Auth / Scope / Technique / PD** | **Rule applied** | **Response** |
| A3 | Default administrator password on the lab LMS replica is tested inside 192.168.56.0/24, not on production. | Y / Y / Y / N | DR4 | **Acceptable – PROCEED**. |

| | | | | |
|---|---|---|---|---|
| B1 | A scan reveals an unregistered server at 10.20.7.5; the tester wants to scan it too. | Y / ? / Y / N | DR2 | **Borderline – PAUSE.** Treated as out of scope until the owner and GB add it in writing. |
| B2 | An in-scope database test shows student marks; tester wants a screenshot as evidence. | Y / Y / Y / Y | DR3 | **Borderline – PAUSE.** Take a screenshot with data masked; report to DPO. |
| B3 | Window ends at 05:00; at 04:55 the tester wants to finish a slow scan until 05:30. | Y / ? / Y / N | DR2 | **Borderline – PAUSE.** Stop at 05:00 or request a written extension. |
| U1 | Tester logs in to the mail server (SYS-09) with credentials found on a file share. | Y / N / N / Y | DR1 | **Unacceptable – STOP**, incident, report to DPO and Legal. |
| U2 | External tester proposes a phishing campaign against students “to test awareness”. | N / N / N / N | DR1 | **Unacceptable – STOP.** Social engineering is excluded; request refused. |
| U3 | After the engagement the tester keeps 500 student records “for research”. | N (expired) / N / N / Y | DR1 | **Unacceptable – STOP**, retrieve and destroy data, incident, possible offence under IT Act ss. 43(b), 72. |

**Evidence that the rules separate acceptable from unacceptable actions.** Nine cases were scored with the same four facts. All three acceptable cases returned PROCEED, all three borderline cases returned PAUSE and all three unacceptable cases returned STOP, so the nine outcomes (3 / 3 / 3) match the intended classification with no overlap. The key separator is that DR1 depends only on authorization, scope and technique and can never be overridden by a later rule, while DR2 and DR3 can always be resolved by a written decision.

## 3.5 How the module preserves trust and keeps the engagement lawful and professional

- **Lawful:** EP1 and EP2 mirror the legal test of unauthorized access, so a tester who follows the module stays on the safe side of IT Act s. 43 and s. 66.
- **Professional:** the checks are written down, tested and applied the same way to internal and external testers.
- **Trustworthy to the university:** system owners know that no test begins without their signature (CK1) and that surprises stop work (CK4).
- **Trustworthy to testers:** honest self-reporting is protected (DR5), so mistakes are reported early rather than hidden.

- **Trustworthy to students:** personal data is never copied (EP7, DR3), and misuse is an incident, not a tolerated risk.

**Evidence delivered for Task 3:** principles EP1–EP9, checks CK1–CK8, decision rules DR1–DR5, nine scenario cases with outcomes and the separation result.

## TASK 4 – Construct a Legal-Compliance Mapping (4 Marks)

***Note:*** *this is an academic mapping as on 2 November 2026. Penalties are statutory maxima. Confirm with the university's legal counsel before use.*

### 4.1 Offences, obligations and penalties

| Law and provision | Offence / obligation | Penalty or consequence | Relevance to the programme |
|---|---|---|---|
| IT Act 2000, s. 43(a)–(b) | Accessing a computer system without the owner's permission; downloading or copying data | Compensation to the affected person (no fixed cap in the section; the Adjudicating Officer hears claims up to ₹5 crore, s. 46) | A test without authorization, or copying data beyond the RoE |
| IT Act s. 43(c)–(g), (i) | Introducing malware; damaging or disrupting a system; denying access; altering information | Compensation (as above) | Intrusive tools on production; denialof-service |
| IT Act s. 66 | Doing any s. 43 act dishonestly or fraudulently | Imprisonment up to 3 years, or fine up to ₹5 lakh, or both | A rogue tester or a criminal actor |
| IT Act s. 66B, 66C | Receiving a stolen computer resource; identity theft (using another's password) | s. 66B: up to 3 years or ₹1 lakh; s. 66C: up to 3 years and ₹1 lakh | Reusing found credentials (case U1) |
| IT Act s. 72 | Disclosing material obtained by power under the Act without consent | Up to 2 years, or fine up to ₹1 lakh, or both | Tester or officer leaks what was seen |
| IT Act s. 72A | Disclosing personal information in breach of a lawful contract | Up to 3 years, or fine up to ₹5 lakh, or both | External assessor leaks personal data |
| IT Act s. 43A and SPDI Rules 2011 | A body corporate that is negligent in protecting sensitive personal data must pay compensation | Compensation (no cap). Stays in force until s. 44(2) of the DPDP Act commences on 13 May 2027 | Passwords and similar data held in SYS-17, SYS-15, SYS-18 |
| IT Act s. 70B and CERT-In Directions (28 April 2022) | Report specified cyber incidents to CERT-In within 6 hours of noticing | Failure to give information: up to 1 year or ₹1 lakh | Real intrusion found during an engagement |

| | | | |
|---|---|---|---|
| DPDP Act 2023, s. 8(5) | Data fiduciary must take reasonable security safeguards | Up to ₹250 crore (Schedule) | Tests must not weaken or expose personal data |
| **Law and provision** | **Offence / obligation** | **Penalty or consequence** | **Relevance to the programme** |
| DPDP Act s. 8(6) | Notify the Data Protection Board and each affected person of a personal-data breach | Up to ₹200 crore (Schedule) | Personal-data exposure found during testing |
| DPDP Act s. 8(2) | A data processor may be engaged only under a valid contract | Fiduciary remains liable | External assessors who see personal data |
| US CFAA, 18 U.S.C. § 1030(a)(2) | Obtaining information from a protected computer without or beyond authorization | Up to 1 year; up to 5 years if for gain or in furtherance of another crime; up to 10 years for a repeat offence | Foreign tester or US-hosted asset |
| CFAA § 1030(a)(5) | Knowingly causing damage by transmitting a program or command (up to 10 years); reckless damage (up to 5 years); damage with loss (up to 1 year) | As stated | Tools that crash a service |
| CFAA § 1030(a)(7) and (g) | Threats to damage or to disclose to extort; civil action for compensation | Up to 5 years; civil damages | Misuse of findings |

## 4.2 India (IT Act and DPDP Act) compared with the US CFAA

| **Point of comparison** | **IT Act 2000 / DPDP Act 2023 (India)** | **CFAA (United States)** |
|---|---|---|
| Core test | Access “without permission of the owner or person in charge” (s. 43) | Access “without authorization” or “exceeds authorized access”; narrowed by Van Buren v. United States (2021) to a gates-up-or-down reading |
| Criminal intent | Criminal liability (s. 66) needs dishonest or fraudulent intent; civil compensation under s. 43 does not | Mostly “intentional” or “knowing”; some offences need damage or loss thresholds |

| | | |
|---|---|---|
| Good-faith research | No statutory safe harbour; written permission is the only reliable defence | No statutory safe harbour; since May 2022 a DOJ charging policy declines to prosecute good-faith research, but it does not bind civil claims |
| Data protection | Separate and now stronger: DPDP Act duties (safeguards, breach notice, processor contract) | No single federal privacy law; state laws and sector rules apply |
| **Point of comparison** | **IT Act 2000 / DPDP Act 2023 (India)** | **CFAA (United States)** |
| Reach | IT Act s. 75 reaches offences outside India that involve a computer in India | "Protected computer" includes any computer used in interstate or foreign commerce |
| Civil remedy | Compensation under ss. 43, 43A | Civil suit under § 1030(g) for qualifying loss |

**Lesson for the design:** neither law offers a safe harbour for a well-meaning tester, so the framework relies on EP1, prior written authorization from the system owner, as its primary legal control.

## 4.3 Controls referenced by the legal mapping

| Control | Description | Implemented in |
|---|---|---|
| C-01 | Written authorization (D1) signed by the system owner before any activity | Task 6; D1 |
| C-02 | Scope register, default-deny scope guard and scope-boundary rules OS1–OS5 | Task 5; Task 7 |
| C-03 | Technique allow-list and prohibited-technique list (no malware release, no denial-of-service) | Task 5 RoE |
| C-04 | Testing windows and blackout periods; stop conditions CK4 | Task 5; Task 3 |
| C-05 | DPO review of every engagement touching personal data | Task 6 workflow |
| C-06 | NDA and data-processing agreement for every external assessor | Task 6; D1 |
| C-07 | Data minimisation: synthetic data in the lab, no copying of real personal data | Tasks 3, 7 |
| C-08 | Encrypted storage, need-to-know access and secure deletion at closure (D6) | Tasks 5, 8 |
| C-09 | Evidence redaction check on every finding report (D3) | Task 8 |

| | | |
|---|---|---|
| C-10 | 24-hour notice of any personal-data finding to the DPO; breach path to the Data Protection Board | Task 6 |
| C-11 | Disclosure only through the coordinated process; no public release of personal data | Task 6 |
| C-12 | Immutable engagement log and report of reportable incidents to CERT-In within 6 hours | Tasks 3, 6 |

### 4.4 Requirement-to-control mapping

| **Legal requirement** | **Control(s)** | **How the control satisfies it** |
|---|---|---|
| IT Act s. 43(a): no access without permission | C-01, C-02, C04 | Access happens only inside the signed scope and window. |
| **Legal requirement** | **Control(s)** | **How the control satisfies it** |
| IT Act s. 43(b): no copying of data | C-07, C-09 | Real data is not copied; evidence is redacted. |
| IT Act s. 43(c)–(g), (i): no damage or disruption | C-03, C-04, CK4 | Low-impact techniques, windows, stop conditions. |
| IT Act s. 66 / 66C: dishonest access, credential misuse | C-01, C-03, CK2 | Authorization proof and tool and target allow-lists. |
| IT Act s. 72 / 72A: confidentiality | C-06, C-08, C11 | NDA, encrypted storage and need-to-know release. |
| IT Act s. 43A: reasonable security for sensitive data | C-05, C-07, C08 | DPO review, minimisation and protected storage. |
| CERT-In 6-hour reporting | C-12 | Stop-and-escalate path and log time-stamps. |
| DPDP s. 8(5): security safeguards | C-05, C-07, C08 | As for s. 43A; built in from day one. |
| DPDP s. 8(6): breach notice | C-10 | DPO is told within 24 hours so the notice clock can be met. |
| DPDP s. 8(2): processor contract | C-06 | No external tester sees personal data without a DPA. |
| CFAA § 1030(a)(2), (a)(5) | C-01, C-02, C03 | The same authorization and scope controls cover US-law exposure. |

All 11 requirements are linked to at least one control, so design criterion DC3 is met.

## 4.5 Which legal requirements apply when a test touches personal data

**Decision.** When a test touches a system that holds personal data (14 of the 20 register entries), the framework applies the **strictest applicable standard**, in this layered way:

1. **IT Act ss. 43, 66, 72, 72A always apply.** They apply to every test whether or not data is involved. Reason: they define unauthorized access and confidentiality, and they are in force today.
2. **IT Act s. 43A and the SPDI Rules apply as the legally binding data standard now** (until 13 May 2027), if the university is a body corporate handling sensitive personal data such as passwords. Reason: the DPDP substantive duties are not yet in force.
3. **DPDP Act ss. 8(2), 8(5), 8(6) are applied as a design standard from day one**, even though their commencement date is 13 May 2027. Reason: the programme will continue beyond that date, rebuilding controls later costs more, and a test that exposes data in 2027 would otherwise be judged by a standard the university never practised.
4. **CERT-In directions apply if a real incident is discovered**, and the 6-hour clock starts when the incident is noticed, not when the report is written.
5. **CFAA applies only if there is a US element** (a US-located tester, a US-hosted cloud asset or US residents' data). It is otherwise used as a benchmark. Reason: Indian law governs Indian systems, but an external assessor may be exposed to US law.

**Trade-off.** Applying the DPDP standard early adds a DPO review to 14 of the 20 systems and slows approval. Task 10 measures that cost and Task 11 shows how it is controlled.

**Evidence delivered for Task 4:** legal mapping (4.1, 4.2), offences-and-penalties table (4.1), 12 controls (4.3), requirement-to-control table (4.4) and the justified conclusion (4.5).

## TASK 5 – Create a Scope and Rules-of-Engagement Document (4 Marks)

The RoE below is the reusable template document **D2**. Values shown are those of the pilot programme; for each engagement the Lead Tester copies the template and fills the engagementspecific fields in square brackets.

### 5.1 Rules-of-engagement document (D2)

| Clause | Content |
|---|---|
| RoE-1 Purpose and authority | Defines what may be tested, when, how and by whom under authorization [AUTH-ID]. It is valid only together with a signed D1 form. It gives no permission beyond what is written. |
| RoE-2 Engagement identity | Engagement ID ENG-YYYY-DEPT-NNN; requester; Lead Tester and team; tester type (internal/external); emergency contact; authorization dates (maximum 30 days). |
| RoE-3 Objectives | Identify and rate weaknesses in the listed systems and verify fixes. Not an attempt to break in, prove compromise or collect data. |
| RoE-4 In-scope systems | Table 5.2: only the register IDs listed in the scope list of this engagement. |
| RoE-5 Out-of-scope | Table 5.3 and the default-deny rule: anything not listed in RoE-4 is out of scope. |
| RoE-6 Testing windows | Weekdays 22:00–05:00 IST for production systems; staging and lab at any time agreed in writing. **Blackout:** examination weeks, admission days, results days and any freeze announced by the CISO. |
| RoE-7 Permitted techniques | Table 5.4. |
| RoE-8 Prohibited techniques | Table 5.4. |
| RoE-9 Data handling | Synthetic data in the lab; real personal data is never copied, screenshotted unmasked or removed; reports and logs are encrypted; all data is destroyed at closure and certified in D6. |
| RoE-10 Communications and escalation | Table 5.5. |
| RoE-11 Stop conditions | Check CK4 (Task 3): unexpected personal data, instability, unclear scope, signs of a real intruder. |
| RoE-12 Reporting and disclosure | Findings only through D3; disclosure only through the Task 6 process; no public statements by testers. |

| | |
|---|---|
| RoE-13 Acceptance | Signatures of the Lead Tester (accepts the rules), the System Owner (permits the test) and the Programme Owner (issues the AUTH-ID). |

## 5.2 In-scope systems and boundaries

| Zone | Meaning | Systems | Allowed testing |
|---|---|---|---|
| Z1 In-scope production | Live university systems listed in this engagement | SYS-01 to SYS-20 as listed per engagement | Non-intrusive only (version checks, configuration review, authenticated scans) inside the window; two-person rule |
| Z2 In-scope lab / staging | Replica systems with synthetic data | Lab 192.168.56.20 and 192.168.56.30; staging if agreed | Full permittedtechnique list, including intrusive tests |
| Z3 Out-of-scope internal | University systems not in this engagement or not in the register | Any other 10.20.x.x host, e.g. unregistered 10.20.7.5 | None |
| Z4 Third-party | Systems the university does not own or control | Cloud-provider infrastructure, payment gateway, vendor-hosted services, student and staff personal devices | None unless the owner signs a separate authorization |

**Naming and boundary rules.** Systems are identified only by register ID (SYS-nn). A scope item is written SC-<ENGAGEMENT>-<nn> and gives the exact address (single IP or exact CIDR), never a wildcard or “all hosts”. A host name is in scope only if it resolves to a registered address on the day of testing. Sub-domains and new IP addresses are not included unless listed.

## 5.3 Out-of-scope examples and detection rules

| Rule | An action is out of scope if… | Detected by |
|---|---|---|
| OS1 | the target is not in the scope register | Register lookup (e.g. SYS-99, 10.20.7.5) |
| OS2 | the target is registered but is not in this engagement’s scope list (e.g. SYS-12 in an LMSonly engagement) | Comparison with the signed scope list (tests T2, L14) |
| OS3 | the technique is not in the permitted list or is in the prohibited list | Tool allow-list check CK3 |

| | | |
|---|---|---|
| OS4 | the time is outside the window or inside a blackout | Clock check against RoE-6 and activity-log review CK6 |
| OS5 | the system belongs to a third party (Zone Z4) | Ownership field in the register; cloud and vendor ranges are on the deny list |

## 5.4 Permitted and prohibited techniques

| **Permitted (Z1 production)** | **Permitted only in the lab or staging (Z2)** | **Prohibited everywhere** |
|---|---|---|
| Host discovery in the listed ranges; service and version identification; authenticated vulnerability scan at low rate; configuration and patch review; TLS and header checks; readonly review of access-control settings | Exploit verification of a known vulnerability against the replica; password-strength testing against lab accounts; webapplication fuzzing of the replica; packet capture on the lab network | Denial-of-service or stress tests; phishing or other social engineering; physical intrusion; installing persistent access or malware on university systems; bruteforcing production accounts; copying real personal data; using found credentials outside the listed scope; pivoting to unlisted systems; changing or deleting data or logs |

## 5.5 Escalation paths

| **Level** | **Trigger** | **Contact (in order)** | **Time limit** |
|---|---|---|---|
| L1 | Tool error, slow target, minor question | Lead Tester → System Owner | Within 30 minutes |
| L2 | Unexpected impact, outage or unclear scope | Stop work → System Owner → Programme Owner | Within 15 minutes |
| L3 | Personal data exposed, or signs of a real intruder | Stop work → Programme Owner and DPO; Legal; CERT-In if reportable | Within 1 hour (6hour CERT-In clock; 24-hour DPO note) |
| L4 | Possible offence, lawenforcement contact, media interest | Legal Counsel and Governance Board | Immediately |

## 5.6 Rules for recording and verifying written authorization

| Rule | Verification rule |
|---|---|
| AV1 | An AUTH-ID (AUTH-YYYY-NNN) exists in the Authorization Register with status ACTIVE. |
| AV2 | The signatory is the owner of **every** system in scope according to the Authority Matrix; the requester's own signature is not enough. |
| AV3 | Separation of duties: requester, signatory and Lead Tester are different people. |
| AV4 | Today lies between the start and end dates; the window is not longer than 30 days; no back-dating. |
| AV5 | Every scope ID is in the register, and an exact address is given for each. |
| **Rule** | **Verification rule** |
| AV6 | If any scope item holds personal data, a DPO approval ID is attached. |
| AV7 | For external testers: NDA and DPA IDs are attached and identity is verified (organisation letter and government ID). |
| AV8 | The signature is from the university e-sign system or institutional e-mail; for external testers a call-back to the signatory confirms it; the signed form is stored with its SHA-256 hash. |
| AV9 | Authorization is non-transferable and expires automatically at the end date; extension needs a new signed D1. |

## 5.7 Transformation of the RoE into a pre-engagement checklist (D2-CL)

Each RoE clause or AV rule is transformed into a yes/no check with the evidence the Lead Tester must attach. The engagement cannot pass gate G2 unless every line is "Yes".

| No. | Checklist item | From | Evidence | Yes / No |
|---|---|---|---|---|
| 1 | AUTH-ID found in the register and status is ACTIVE | AV1 | Register screenshot | ☐ |
| 2 | Signatory owns every system in scope | AV2 | Authority-matrix extract | ☐ |
| 3 | Requester, signatory and tester are different people | AV3 | D1 form | ☐ |
| 4 | Dates cover the activity; window is 30 days or less | AV4 | D1 form | ☐ |

| | | | | |
|---|---|---|---|---|
| 5 | All scope items are register IDs with exact addresses | AV5; RoE-4 | Scope list | ☐ |
| 6 | DPO approval attached if personal data is in scope | AV6 | DPO approval ID | ☐ |
| 7 | NDA and DPA attached and identity verified (external only) | AV7 | NDA and DPA IDs | ☐ |
| 8 | Signature verified and signed form hashed | AV8 | SHA-256 value | ☐ |
| 9 | Testing window is outside every blackout period | RoE-6 | Calendar check | ☐ |
| 10 | Tools used are on the allow-list | RoE-7; CK3 | Tool list | ☐ |
| 11 | Conflict-of-interest declaration signed | CK7 | Declaration | ☐ |
| 12 | Lab verified isolated (OP-L1, OP-L3) and recorded (OP-L2) | Task 7 | Lab record file | ☐ |
| 13 | Escalation contacts confirmed and reachable | RoE-10 | Contact sheet | ☐ |
| **No.** | **Checklist item** | **From** | **Evidence** | **Yes / No** |
| 14 | Second person on standby for production tests | CK5 | Name and phone | ☐ |

**Evidence delivered for Task 5:** RoE document D2 (5.1–5.5), authorization-verification rules AV1–AV9 (5.6), scope boundaries and out-of-scope detection rules OS1–OS5 (5.2, 5.3) and the derived 14-item checklist (5.7).

## TASK 6 – Build an Authorization and Disclosure Layer (5 Marks)

Version v1.0 is described here: the Security Officer reviews every request and triages every finding. Task 10 measures this design and refines it (v1.2).

### 6.1 Authorization workflow

| State | Entered when | Actor | Guard (must be true) | Record written |
|---|---|---|---|---|
| DRAFT → SUBMITTED | Requester submits form D1 | Requester | All required fields filled; scope IDs exist | Request ID, time stamp |
| SUBMITTED → UNDER REVIEW | Security Officer opens the request | Security Officer | Dates valid; window ≤ 30 days; no backdating | Reviewer, risk note |
| UNDER REVIEW → LEGAL HOLD (optional) | Personal data or external tester involved | DPO, Legal | DPO approval (C-05); NDA and DPA (C-06) | DPO ID, NDA ID, DPA ID |
| UNDER REVIEW → APPROVED | All checks pass | Security Officer (GB for high risk) | AV1–AV9 satisfied | Approval note |
| APPROVED → SIGNED | System Owner(s) sign | System Owner | Signatory is owner of every scope item (AV2) | Signature hash |
| SIGNED → ACTIVE | AUTH-ID issued and written to the register | Programme Owner | Pre-engagement checklist complete (D2-CL) | AUTH-ID, log entry |
| ACTIVE → COMPLETED / EXPIRED | Work ends or end date passes | Lead Tester / system | Automatic at end date (AV9) | Closing note, D6 |
| any → REJECTED / SUSPENDED | A check fails or a stop condition occurs | Reviewer or Programme Owner | Reason recorded | Reason code |

### 6.2 Responsible (coordinated) disclosure process

| Step | Timing | What happens |
|---|---|---|
| 1 Validate | Day 0 | Lead Tester and Disclosure Coordinator confirm the finding in the lab and rate it with CVSS (D3). |

| | | |
|---|---|---|
| 2 Notify owner | Within 1 working day | System Owner receives the D4 notice by secure channel. If personal data is involved, the DPO is told within 24 hours (C-10). |
| **Step** | **Timing** | **What happens** |
| 3 Acknowledge | Within 2 working days | Owner confirms receipt and names a fixer. No acknowledgement triggers escalation. |
| 4 Remediation window | Critical 30 days; High 60; Medium 90; Low 120 (v1.0) | Owner fixes. Status is updated in the log. One extension of up to 50 % of the window may be granted by the Programme Owner if progress is shown. |
| 5 Verify fix | After the fix | Tester re-checks in the lab or in staging. Status becomes REMEDIATED. |
| 6 Release | After step 5, or at the deadline under the decision rules | A redacted summary is shared inside the university (and with the vendor or CERT-In if a third-party product is affected). Personal data is never released. |
| 7 Close | After release | Lessons learnt; D6 closure certificate; data destroyed. |

**Reporting format.** D3 (Task 8) carries: finding ID, engagement ID, asset ID, title, description, severity and CVSS score, steps to reproduce (lab), impact, recommended fix, evidence reference (redacted), personal-data flag, found date, computed deadline and disclosure track. It is machinereadable (JSON) so that the next component can use it without retyping.

## 6.3 Coordinated disclosure compared with full disclosure and bug bounty

| **Criterion** | **Coordinated (chosen default)** | **Full disclosure** | **Bug bounty** |
|---|---|---|---|
| Who learns first | Owner only, then a redacted summary | Everyone at once | Programme and the reporter; public later if at all |
| Risk of exploitation before the fix | Low | High | Low to medium |
| Pressure on owner to fix | Medium: fixed window, escalation | Very high | Medium: payment and reputation |
| Risk of exposing personal data | Low | High | Medium: outsiders may touch live data |

| | | | |
|---|---|---|---|
| Fit for 20 to many systems | Good: one process, one clock | Poor for internal systems | Good only later, with legal safe-harbour terms and vetted reporters |
| Cost and control | Staff time only | Free but uncontrolled | Cash and platform; needs mature triage |
| Verdict for the university | **Default** | **Exception** (rule below) | **Not at this stage**; reconsidered in Task 11 |

## 6.4 Operations for logging, status and release decisions

Three operations are implemented in the reference program (Appendix A) and tested in Tasks 8, 9 and 11.

| **Operation** | **Inputs** | **Output** | **Behaviour** |
|---|---|---|---|
| log_approval(request, decision) | Request ID, approver, decision, reason, time | Log entry with SHA-256 chain | Appends only; no entry can be edited. Used by validate_auth for APPROVED / HOLD / REJECT. |
| update_status(finding, status) | Finding ID, status (OPEN, ACKNOWLEDGED, REMEDIATED, EXTENDED), time | Updated record and log entry | Moves the finding along; an overdue OPEN finding raises an escalation. |
| can_disclose(record, today, status) | Finding record, date, status, owner acknowledgement, exploited-in-the-wild flag | WAIT / DISCLOSE_SUMMARY / ESCALATE_GB / FULL_DISCLOSURE_REVIEW | Decision table in 6.5. |

## 6.5 Rules for choosing coordinated or full disclosure

| **Rule** | **Condition** | **Result** |
|---|---|---|
| DS1 | Default for every finding | Coordinated track |

| | | |
|---|---|---|
| DS2 | The flaw is in a third-party product (vendor software, cloud service) | Coordinated with the vendor, through CERT-In if the vendor does not respond |
| DS3 | The finding involves personal data | Never public; internal redacted summary only; DPO leads |
| DS4 | Window expired and the owner has not acknowledged, with no personal data and active exploitation known | FULL_DISCLOSURE_REVIEW: the GB alone may approve a warning notice (no exploit detail) |
| DS5 | Window expired but the owner is working on it | ESCALATE_GB: extension or interim mitigation, not disclosure |
| DS6 | The fix is verified | DISCLOSE_SUMMARY (redacted), then close |

### 6.6 Evidence that the layer interacts correctly with the RoE and legal components

| **Event** | **Component that reacts** | **Result observed in the reference run** |
|---|---|---|
| Authorization lists SYS-99 | RoE scope rule OS1 / AV5 | REJECT (test L6) |
| Finding raised on SYS-12 under an LMS-only authorization | RoE scope rule OS2 | REJECT, OUT_OF_SCOPE_ASSET (T2, L14) |
| Scope holds personal data but no DPO approval | Legal control C-05 | HOLD, DPO_REVIEW (L7) |
| External tester, personal data, no NDA/DPA | Legal control C-06 (IT Act s. 72A, DPDP s. 8(2)) | HOLD, NDA_REQUIRED / DPA_REQUIRED (T3) |
| Finding dated after authorization expired | Authorization window AV4 | REJECT, OUTSIDE_AUTH_WINDOW (T4) |
| Personal-data finding past its deadline | Disclosure rule DS3 and control C-11 | ESCALATE_GB; never public (T5) |
| Personal-data finding recorded | Legal control C-10 | notify_dpo_by = found date + 1 day in the D3 record |

**Evidence delivered for Task 6:** authorization workflow (6.1), responsible-disclosure process and reporting format (6.2), comparison (6.3), operations (6.4), disclosure rules (6.5) and interaction evidence (6.6).

## TASK 7 – Design an Isolated Ethical-Hacking Lab (5 Marks) 7.1

## Lab design

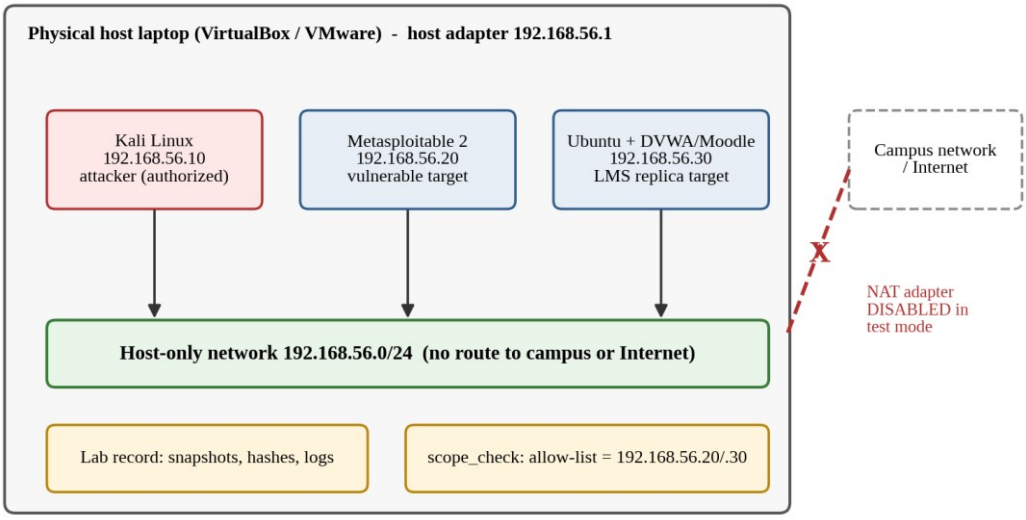



*Figure 2: Isolated lab on a host-only network 192.168.56.0/24*

| Component | Role | Address | Connectivity | Notes |
|---|---|---|---|---|
| Host laptop (VirtualBox or VMware) | Runs the VMs; keeps the lab record | 192.168.56.1 (host-only adapter) | Host-only adapter; its own NIC to campus network is not bridged to any VM | Host firewall blocks forwarding between adapters |
| Kali Linux VM | Authorized attacker machine | 192.168.56.10 (static) | One adapter: hostonly. NAT adapter exists only in prep mode | Tools allowed by D2; scope_check.sh wrapper |
| Metasploitable 2 VM | Deliberately vulnerable Linux target | 192.168.56.20 (static) | Host-only only | Universityowned lab image; no real data |
| Ubuntu VM with DVWA / LMS replica | Web and LMS replica target with synthetic data | 192.168.56.30 (static) | Host-only only | Used for the walkthrough (Task 9) |
| Host-only network | Private network for all lab traffic | 192.168.56.0/24 (reserved range) | No route to campus network or Internet | Built-in DHCP disabled or limited to .100–.254; lab hosts use .10–.50 |

## 7.2 Set-up and recording steps

1. Create or confirm the host-only network 192.168.56.0/24 in the hypervisor and note the host adapter address (192.168.56.1).
2. Import the Kali, Metasploitable 2 and Ubuntu images. Record the SHA-256 of each downloaded image and compare it with the publisher's value.
3. Prep mode: with the targets powered off, give Kali a temporary NAT adapter, update it, then remove the NAT adapter.
4. Test mode: set every VM to a single host-only adapter and assign the static addresses in the table.
5. Run OP-L1 (connectivity), OP-L3 (isolation) and OP-L2 (record); take a clean snapshot named baseline-<date>.
6. Open a lab-use entry LAB-YYYY-NNN that cites the engagement's AUTH-ID. After testing, revert each VM to the snapshot.

## 7.3 Operations

**OP-L1 verify_connectivity (run on Kali)** ip -br addr show # expect 192.168.56.10/24 on the host-only NIC ip route # expect only: 192.168.56.0/24 dev eth0 (no default route)
ping -c 3 192.168.56.20 # expect 0% packet loss ping -c 3 192.168.56.30 # expect 0% packet loss
nmap -sn 192.168.56.0/24 # expect 4 hosts up: .1 (host), .10 (Kali), .20, .30

**OP-L3 verify_isolation (run on Kali; every line must FAIL)** ping -c 2 -W 2 8.8.8.8 # expect 100% packet loss
ping -c 2 -W 2 10.20.1.10 # a campus address from the register: must fail curl -m 5 http://example.com # expect timeout or name-resolution failure

**OP-L2 record_lab_setup (run on Kali, then on the host)**

```
{ date; uname -a; head -2 /etc/os-release; ip -br addr; ip route; nmap -V | head -1; }
> lab_record_$(date +%F).txt sha256sum lab_record_*.txt >> lab_hashes.txt # on
the host:
VBoxManage list vms
VBoxManage showvminfo "Kali-Lab" --machinereadable | grep -E "^(nic|VMState)"
VBoxManage snapshot "Kali-Lab" take "baseline-2026-11-16" --description "clean authorized
state"
```

**Scope guard used by Kali (scope_check.sh)**

```
#!/bin/bash
# usage: ./scope_check.sh <target-ip> <nmap options> ALLOW="192.168.56.20
192.168.56.30"
t="$1"; shift
```

```
case " $ALLOW " in
  *" $t "*) exec nmap "$@" "$t" ;;
  *) echo "BLOCKED: $t is not on the lab allow-list"; exit 1 ;; esac
```

| **Operation** | **Expected result (pass condition)** | **Evidence to attach from your class session** |
|---|---|---|
| OP-L1 | Both targets answer ping; no default route; 4 hosts up | Screenshot of ip route and nmap -sn output |
| OP-L3 | All three external tests fail | Screenshot showing 100% loss and the curl failure |
| OP-L2 | Lab record file, its hash and a snapshot exist | The lab_record file, hash line, snapshot name |

*The "expected result" column is the design specification. During the lab session, run the commands and paste your own screenshots in the third column.*

## 7.4 Host-only compared with NAT

| **Criterion** | **Host-only** | **NAT (per VM)** | **NAT Network** | **Bridged** |
|---|---|---|---|---|
| Isolation from campus and Internet | Complete (no route out) | None: VM can reach the Internet | None: shared NAT to the Internet | None: VM sits on the campus LAN |
| VM to VM communication | Yes | No (each VM isolated) | Yes | Yes |
| Host to VM access | Yes | Only with port forwarding | Only with port forwarding | Yes |
| Updates and downloads | Not possible (use prep mode) | Possible | Possible | Possible |
| Risk of an out-ofscope scan reaching real systems | Very low | Medium | Medium | **High** |
| Reproducible, reserved addresses | Yes (192.168.56.0/24) | Same 10.0.2.x on every VM | Yes | No: addresses from campus DHCP |

**Final lab model.** Host-only for all testing (test mode) plus a short, controlled prep mode in which only Kali has a NAT adapter and the targets are off. Host-only is chosen because the main risk in the scenario is an unauthorized or out-of-scope connection, and host-only removes the route by design instead of relying on the tester's care. Plain NAT was rejected because VMs cannot reach each other

and Kali can reach the Internet; NAT Network was rejected for the Internet path; bridged was rejected because it puts attack tools on the campus LAN. The trade-off is that updates need the prep step, which costs a few minutes and is recorded.

## 7.5 How the lab keeps testing authorized and contained

- **Authorized:** only university-owned or properly licensed images are used, and each session is tied to a lab-use entry that cites the AUTH-ID (gate G2).
- **Network containment:** no route leaves 192.168.56.0/24 (checked by OP-L3 before every session).
- **Target containment:** scope_check.sh allows only 192.168.56.20 and .30, so a typing error cannot send a scan to a campus address.
- **Data containment:** targets use synthetic data only (C-07).
- **Recoverable and auditable:** snapshots allow a reset, and the lab record plus hashes prove the configuration at test time.

**Evidence delivered for Task 7:** lab design and figure (7.1), component and connectivity table, setup and recording steps (7.2), three operations with pass conditions (7.3), network comparison and justified model (7.4) and the containment explanation (7.5).

## TASK 8 – Develop a Reusable Document Library (5 Marks)

| ID | Document | Purpose | Used at gate |
|---|---|---|---|
| D1 | Engagement Authorization Form | Written permission signed by system owners | G1 |
| D2 | Scope and Rules of Engagement (with pre-engagement checklist D2CL) | Defines what, when and how (Task 5) | G2 |
| D3 | Finding Report (structured output) | One finding per record; feeds legal and disclosure components | G4 |
| D4 | Disclosure Notification | Notice to the system owner (and DPO) with the remediation window | G5 |
| D5 | Stop-Work and Incident Notice | Records a stop condition or a rule breach and its escalation | any |
| D6 | Engagement Closure and DataDestruction Certificate | Closes the authorization and certifies data deletion | G5 |

### 8.1 D1 – Engagement Authorization Form

| Field | Default / format | Validation rule |
|---|---|---|
| engagement_id | ENG-YYYY-DEPT-NNN (auto) | Required; unique |
| requester | Name and department | Required; must differ from signed_by |
| signed_by | System owner name (e-sign) | Required; not blank; must be owner of every scope ID (AV2) |
| start, end | Start default = today; end default = start + 4 days | end > start; start ≥ today; length ≤ 30 days |
| scope_ids | List of SYS-nn | Required; each ID in the register |
| tester, tester_type | Name or ID; internal (default) / external | Required |
| emergency_contact | Programme Owner's hotline (default) | Required |
| dpo_approved | False (default) | Must be True when any scope ID holds personal data |

| | | |
|---|---|---|
| nda_signed, dpa_signed | False (default) | External testers: nda_signed True; and dpa_signed True when personal data is in scope |
| window | 22:00–05:00 IST (default) | Must be outside blackout dates |

## 8.2 D3 – Finding Report

| Field | Default / format | Validation rule |
|---|---|---|
| finding_id | FND-<ENG>-NNN (auto) | Required; unique |
| engagement_id | From the authorization | Must match an ACTIVE authorization |
| asset_id | SYS-nn | Must be in the register and in the authorization's scope list |
| title, description, steps_to_reproduce, impact, recommendation | Free text | Title required |
| cvss | Number 0.0–10.0 | Within range |
| severity | Derived from cvss: 9.0+ Critical; 7.0–8.9 High; 4.0–6.9 Medium; 0.1–3.9 Low; 0 Info | Must agree with the cvss band |
| found_on | Today | Between the authorization start and end dates |
| evidence_redacted | False (default) | Must be True when the asset holds personal data |
| production_exposure | "To be confirmed by System Owner" | Lab findings do not claim production impact until confirmed |
| personal_data (computed) | From the register | If True, notify_dpo_by = found_on + 1 day |
| deadline (computed) | found_on + window for the severity | Critical 30; High 60; Medium 90; Low 120 days (v1.0) |
| track (computed) | COORDINATED | Changed only by the GB (rule DS4) |

## 8.3 D4, D5 and D6 – key fields

| Document | Fields (defaults in brackets) |
|---|---|
| D4 Disclosure Notification | finding_id; owner; severity; summary without exploit detail; remediation deadline (from D3); acknowledgement due (2 working days); DPO copy (yes if personal_data); secure channel (encrypted mail); extension allowed (one, 50 %) |
| D5 Stop-Work and Incident Notice | engagement_id; time; stop rule (CK4 item); description; systems affected; personal data involved (no); action taken; escalation level (L2); CERT-In reportable (to be decided by Programme Owner) |
| D6 Closure and Data-Destruction Certificate | engagement_id; closing date (today); findings count; open findings (0); data held (none); destruction method (secure deletion, VM revert); witness; AUTH-ID status set to COMPLETED |

## 8.4 Structured output of D3 and integration with other components

The record below was produced by the reference program (Appendix A) from the finding **FND-LMS001**. It is the structured output of D3 and is the input of the disclosure layer.

```
{
  "finding_id": "FND-LMS-001",
  "engagement_id": "ENG-2026-LMS-001",
  "asset_id": "SYS-05",
  "severity": "High",
  "cvss": 8.1,
  "personal_data": true,
  "found_on": "2026-11-17",
  "notify_dpo_by": "2026-11-18",
  "deadline": "2027-01-16",
  "track": "COORDINATED"
}
```

| Field in the output | Consumed by | Effect |
|---|---|---|
| asset_id, engagement_id | Scope guard (Task 5) | Checked against the authorization's scope list (OS2) |
| personal_data, notify_dpo_by | Legal controls C-05, C-10 (Task 4) | DPO is told within 24 hours; public release is blocked (DS3) |
| severity, deadline | Disclosure layer (Task 6) | Starts the remediation clock; drives can_disclose |
| track | Disclosure decision rules DS1–DS6 | Coordinated by default; changed only by the GB |

| | | |
|---|---|---|
| finding_id | Engagement log and D6 | Counted in the closure certificate |

## 8.5 Test entries: valid, boundary and invalid

Fourteen test entries were run against D1 and D3 with the validation program. “Expected” is what the rules require; “Result” is what the program returned.

| No. | Document | Type | Test entry | Expected | Result | Pass |
|---|---|---|---|---|---|---|
| L1 | D1 Authorization | Valid | All fields present, 5-day window, internal tester | APPROVED | APPROVED | Yes |
| L2 | D1 Authorization | Boundary | Window of exactly 30 days (16 Nov - 15 Dec) | APPROVED | APPROVED | Yes |
| **No.** | **Document** | **Type** | **Test entry** | **Expected** | **Result** | **Pass** |
| L3 | D1 Authorization | Boundary | Window of 31 days (16 Nov - 16 Dec) | REJECT | REJECT | Yes |
| L4 | D1 Authorization | Boundary | Start date equals today (9 Nov) | APPROVED | APPROVED | Yes |
| L5 | D1 Authorization | Invalid | Sign-off field blank | REJECT | REJECT | Yes |
| L6 | D1 Authorization | Invalid | Scope contains SYS-99 (not in register) | REJECT | REJECT | Yes |
| L7 | D1 Authorization | Invalid | Personal-data scope without DPO approval | HOLD | HOLD | Yes |
| L8 | D3 Finding report | Valid | CVSS 8.1 labelled High, redacted evidence | ACCEPT | ACCEPT | Yes |
| L9 | D3 Finding report | Boundary | CVSS 9.0 labelled Critical | ACCEPT | ACCEPT | Yes |

| | | | | | | |
|---|---|---|---|---|---|---|
| L10 | D3 Finding report | Boundary | CVSS 8.9 labelled Critical (should be High) | REJECT | REJECT | Yes |
| L11 | D3 Finding report | Boundary | Found on last day of authorization (20 Nov) | ACCEPT | ACCEPT | Yes |
| L12 | D3 Finding report | Invalid | CVSS 10.5 (out of range) | REJECT | REJECT | Yes |
| L13 | D3 Finding report | Invalid | Evidence contains unredacted personal data | REJECT | REJECT | Yes |
| L14 | D3 Finding report | Invalid | Asset SYS-12 outside engagement scope | REJECT | REJECT | Yes |

**Result: 14 of 14 test entries passed.** The boundary entries show that a 30-day window is accepted and a 31-day window rejected, that CVSS 9.0 is Critical while 8.9 is not, and that a finding on the last authorized day is accepted.

**Evidence delivered for Task 8:** six documents (D1–D6), field tables for D1 and D3, key fields for D4–D6, a structured JSON output that feeds the scope, legal and disclosure components, and 14 valid/boundary/invalid test entries.

## TASK 9 – Integrate, Test and Refine the Framework (5 Marks)

### 9.1 Integrated framework

The components of Tasks 2–8 are joined as one chain. Each row names the output of one stage that the next stage consumes.

| Stage | Components used | Gate | Output handed to next stage |
|---|---|---|---|
| 1 Request | D1 form; register (Task 8, 5); threat model priority (Task 2) | — | Request with scope IDs and risk flags |
| 2 Authorization | Workflow (Task 6); AV1–AV9 (Task 5); legal controls C-01, C-05, C-06 (Task 4) | G1 | AUTH-ID, signed D1, log entry |
| 3 Preengagement | RoE D2 and checklist (Task 5); conduct module CK1–CK8 (Task 3) | G2 | Completed checklist |
| 4 Lab testing | Isolated lab and operations (Task 7); decision rules DR1–DR5 (Task 3) | G3 | Lab record, activity log, raw observations |
| 5 Reporting | D3 validation (Task 8); redaction check C-09 | G4 | Structured finding record (JSON) |
| 6 Disclosure | D4, DS1–DS6, can_disclose (Task 6); C-10, C-11 | G5 | Owner notice, status updates, redacted summary |
| 7 Closure | D6; log verification | — | AUTH-ID COMPLETED; data destroyed |

### 9.2 Walkthrough of one authorized assessment

**Scenario.** The Dean of the School of Computing asks for an assessment of the LMS (SYS-04 to SYS07) before the upgrade. The tester is internal (T-07). The LMS holds personal data (grades). Dates below were produced by the reference program.

| Date | Stage | What happens | Framework response / recorded result |
|---|---|---|---|
| 9 Nov 2026 | Request | Dean submits D1 for ENG-2026LMS-001: scope SYS-04–07, 16– 20 Nov, tester T-07, DPO approval attached. | SUBMITTED; register lookup finds all four IDs. |
| 11 Nov | Authorization | Security Officer reviews; DPO approval present; Registrar signs as owner. | validate_auth → **APPROVED**, reason OK; log entry written; AUTH-ID issued. |
| 13 Nov | Preengagement | Lead Tester completes the 14-item checklist. | Gate G2 passes; window 22:00–05:00; no blackout. |

| Date | Stage | What happens | Framework response / recorded result |
|---|---|---|---|
| 16 Nov | Lab | Lab built and verified (OP-L1, OPL3, OP-L2); LMS replica with synthetic data on 192.168.56.30; snapshot taken. | Isolation confirmed; lab-use entry cites the AUTH-ID. |
| 17 Nov | Testing in lab | On the replica, tester finds an outdated LMS plugin with an input-validation flaw (CVSS 8.1). Production is not touched; production exposure is left "to be confirmed". | Finding drafted in D3 for asset SYS-05. |
| 17 Nov | Reporting | D3 submitted; evidence masked. | validate_finding → **ACCEPT**: severity High, personal_data true, notify DPO by 2026-11-18, deadline 2027-01-16 (v1.0 window of 60 days). |
| 19 Nov | Disclosure | Owner notified with D4 and acknowledges within 2 working days; plugin update is scheduled. | Status ACKNOWLEDGED logged. |
| 1 Dec | Monitoring | Fix not yet done but deadline not reached. | can_disclose → **WAIT**. |
| 10 Dec | Verification | Owner updates the plugin; tester re-checks in the lab. | Status REMEDIATED; can_disclose → **DISCLOSE_SUMMARY** (redacted summary inside the university only). |
| 10 Dec | Closure | D6 completed; lab reverted to snapshot; data destroyed. | Log has 4 entries; chain intact: true; editing one entry is detected: true. |

| No. | Test case | Expected | v1.0 result |
|---|---|---|---|
| T1 | Missing written authorization (empty signoff) | REJECT | APPROVED (**FAIL**) |

| No. | Test case | Expected | v1.0 result |
|---|---|---|---|
| T2 | Out-of-scope request (finding on SYS-12) | REJECT | ACCEPT (**FAIL**) |
| T3 | Legal conflict (external tester, personal data, no DPA) | HOLD | APPROVED (**FAIL**) |
| T4 | Activity after authorization expired (found 25 Nov) | REJECT | ACCEPT (**FAIL**) |
| T5 | Delayed disclosure (window expired, personal data) | ESCALATE_GB | PUBLIC_DISCLOSURE (**FAIL**) |
| T6 | Valid request, inscope finding, fix before deadline | APPROVED+ACCEPT+DISCLOSE_SUMMARY | APPROVED+ACCEPT+DISCLOSE (pass) |

## 9.3 Systematic test cases

Six test cases were run twice with the same program: first against framework v1.0 (all refinements switched off) and then against v1.1 (refinements F1–F5 switched on).

**Result:** v1.0 passed 1 of 6 tests; v1.1 passed 6 of 6. The tests cover the four required situations: missing authorization (T1), out-of-scope request (T2), legal conflict (T3, T4) and delayed disclosure (T5), plus one normal path (T6).

## 9.4 Problems found and refinements made

| No. | Problem encountered | Why it mattered | Refinement | Verified by |
|---|---|---|---|---|

| | | | | |
|---|---|---|---|---|
| F1 | A form with an empty sign-off field was approved because the check only looked for the field's presence. | Breaks EP1: authorization without a signature. | An empty or blank value counts as missing. | T1, L5 |
| **No.** | **Problem encountered** | **Why it mattered** | **Refinement** | **Verified by** |
| F2 | A finding on SYS-12 was accepted because SYS-12 exists in the register, although the engagement covered only SYS-04–07. | Breaks EP2: outof-scope work is accepted. | Finding's asset must be in the authorization's own scope list. | T2, L14 |
| F3 | An external tester with personal data in scope was approved without an NDA or data-processing agreement. | IT Act s. 72A and DPDP s. 8(2) exposure. | External tester requires NDA; external plus personal data also requires DPA (HOLD otherwise). | T3 |
| F4 | A finding dated after the authorization ended was accepted. | Work after expiry is unauthorized (AV9). | Finding date must lie within start and end dates. | T4, L11 |
| F5 | When the deadline passed, the decision was PUBLIC_DISCLOSURE, even for a personal-data finding. | Would publish student data; breaks DS3, C-11. | Personal-data findings are never released; overdue items go to the GB; full disclosure only by GB review. | T5 |
| F6 | The lab finding implied that production was vulnerable without proof. | Risk of false alarm or of testing production to "confirm". | D3 gets a production_exposure field; owner confirms, tester does not touch production. | Design review (not code) |

## 9.5 Final corrected framework (v1.1)

Version v1.1 is v1.0 plus F1–F6. All 6 integration tests and all 14 library tests pass, the log chain verifies, and the walkthrough reproduces from the program. The corrected rules are the ones printed in Tasks 5, 6 and 8 and in Appendix A. To reproduce: install Python 3, save the files described in Appendix A and run **python3 framework.py**.

**Evidence delivered for Task 9:** integrated framework (9.1), walkthrough (9.2), systematic tests including missing authorization, out-of-scope, legal conflict and delayed disclosure (9.3), problems and refinements (9.4) and the corrected framework (9.5).

## TASK 10 – Create a Scalability and Governance Evaluation (5 Marks) 10.1 Scenarios

| Parameter | Small programme (one department) | Large programme (whole university) |
|---|---|---|
| Departments | 1 | 12 |
| Systems in the register | 6 | 150 |
| Testers | 4 (all internal) | 36 (12 external, 33 %) |
| Engagement requests per month | 8 | 60 |
| Findings per month | 6 | 60 (30 % Critical/High) |
| Share of requests touching personal data | 40 % | 40 % |
| Average systems per engagement | 2 | 4 |

### 10.2 Experiment set-up

Three processes of the framework were modelled and compared in two versions. **Baseline = v1.0:** one Security Officer reviews every request (mean 2.0 h, plus 3 h for an external tester and 1 h when personal data is involved); the officer also triages every finding (1.5 h plus 0.5 h to find the owner); scope is checked system by system. **Refined = v1.2:** requests are risk-tiered (no personal data and an internal tester = Tier 1, approved by the Department Authoriser, mean 0.5 h; all others = Tier 2, reviewed by Governance Board panels, 1 panel in the small and 3 in the large programme); the owner is found by register lookup; only Critical and High findings go to Disclosure Coordinators (1 in small, 3 in large, mean 1.6 h).

| Process | Measure recorded |
|---|---|
| P1 Authorization approval | Median and 90th-percentile turnaround (working hours); percentage approved within 40 working hours (SLA); number of workflow steps |
| P2 Scope verification | Number of manual steps per engagement: baseline 4 + 2 per system; refined 5 (one register lookup for the whole scope list) |
| P3 Disclosure notification | Median and 90th-percentile time from validated Critical/High finding to owner notification (working hours) |

**Method.** Requests and findings arrive at random (Poisson) over one working month of 160 hours; review times are exponential with the means above; the system is a first-come-first-served queue.

Each scenario was repeated 300 times with fixed random seeds, so the numbers can be reproduced by running sim.py. **The arrival rates and review times are assumptions, not measurements.**

## 10.3 Results

| Measure | Small baseline (v1.0) | Small refined (v1.2) | Large baseline (v1.0) | Large refined (v1.2) |
|---|---|---|---|---|
| P1 median approval (h) | 1.9 | 0.7 | 27.6 | 1.2 |
| P1 90th percentile (h) | 6.8 | 4.6 | 76.2 | 8.1 |
| P1 approved within 40 h (%) | 100.00 | 100.00 | 64.73 | 99.96 |
| P1 workflow steps per request | 6.0 | 3.8 | 6.0 | 4.2 |
| P2 scope-check steps | 8 | 5 | 12 | 5 |
| P3 Critical/High median notice (h) | 1.5 | 1.0 | 4.9 | 1.1 |
| P3 90th percentile (h) | 5.3 | 3.9 | 15.8 | 3.6 |

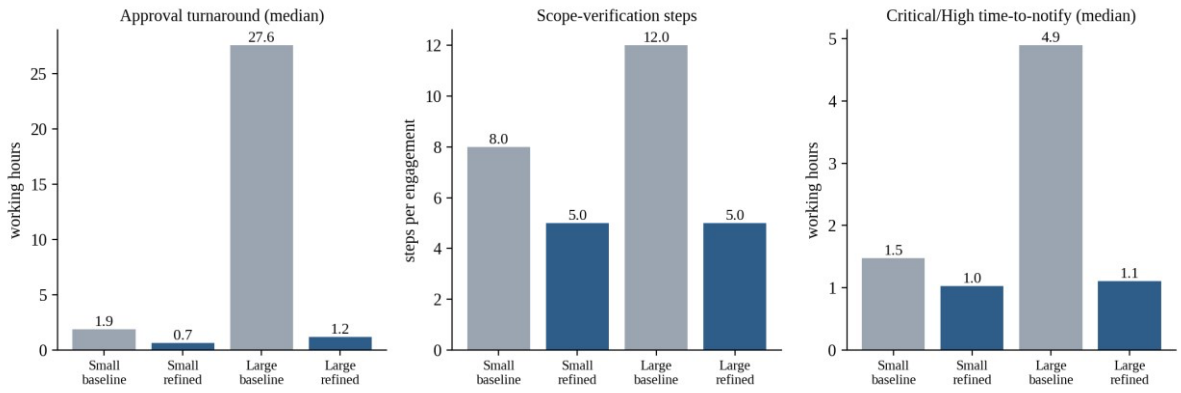



*Figure 3: Baseline against refined governance, small and large programmes (source: sim.py)*

## 10.4 Interpretation

- **The baseline works for one department and fails at university scale.** Median approval grows from 1.9 h to 27.6 h, and only 64.73 % of requests meet the 40-hour SLA. Reason: at 60 requests a month the single reviewer's workload (about 3.4 h per request) exceeds the 160 hours available, so a queue builds up. This fails design criterion DC5 (95 %).
- **Scope checking grows with the number of systems** (8 steps in the small programme and 12 in the large) when done by hand, but stays at 5 steps when a register lookup replaces it.
- **Disclosure notice slows too:** the median for Critical/High findings rises from 1.5 h to 4.9 h and the 90th percentile reaches 15.8 h, because every finding queues behind Medium and Low items.

- **After refinement the large programme meets the criteria:** 99.96 % of approvals within 40 h (median 1.2 h) and Critical/High notice at a median of 1.1 h. The refined small programme is also faster, so the refinement does not penalise small users.

## 10.5 Governance refinements made because of the results

| Evidence | Governance change (v1.2) | Effect |
|---|---|---|
| Large baseline: 64.7 % within SLA; queue at the single reviewer | Risk-tiered approval: Department Authorisers approve Tier 1 (no personal data, internal tester); Governance Board panels handle Tier 2; any engagement touching personal data or an external assessor always stays Tier 2 (legal controls are not weakened). | Approval within SLA rose to 99.96 % and median fell from 27.6 h to 1.2 h. |
| Manual scope checking grows with systems (12 steps) | Scope list entered by register ID; one automated lookup and the allow-list produce the check. | Constant 5 steps; fewer chances for a typing error. |
| Critical/High findings wait behind low-priority ones | Only Critical/High findings are triaged by Disclosure Coordinators; others are routed by the register and tracked on the clock. | Median notice fell from 4.9 h to 1.1 h in the large programme. |

**Evidence delivered for Task 10:** two scenarios (10.1), reproducible set-up (10.2), comparison table and chart (10.3), interpretation (10.4) and governance refinement (10.5).

# TASK 11 – Defend the Framework Under a Changed Requirement (5 Marks)

## 11.1 The changed requirement

The university now runs **continuous** and **third-party** assessments, with **stricter data-protection rules** and a **shorter disclosure timeline**, and wants the framework to stay easy to govern and extend. Four pressures follow: (a) many more approvals, because assessments repeat; (b) more external people near personal data; (c) tighter data duties, which in India will include the DPDP Act duties from 13 May 2027; (d) shorter remediation windows.

## 11.2 Decision for each component: retain, modify, replace or redesign

| Component | Decision | What changes and why |
|---|---|---|
| Threat model and classification (Task 2) | **Retain / modify** | Classification stays. Add "third-party assessor misuse" as an insider-like threat (UNAUTH-INT… when an assessor exceeds scope) so external testers are covered by the same rules. |
| Ethics module (Task 3) | **Modify** | Add an assessor attestation to the code of conduct and a continuous-activity check in CK6 (weekly log review becomes automated alerts). |
| Legal mapping (Task 4) | **Modify** | DPDP Act duties (ss. 8(2), 8(5), 8(6)) become the primary data standard; s. 43A is kept only until it is omitted on 13 May 2027. Review date set for that day. |
| Scope and RoE (Task 5) | **Modify** | Add a baseline scope plus change control: widening scope needs a new request. Add recurring windows. |
| Authorization workflow (Task 6) | **Redesign** | Per-engagement approval does not suit continuous work. Replace with a standing authorization (new component N1). |
| Disclosure layer (Task 6) | **Modify** | Shorter windows and an automatic disclosure clock (N3); bug bounty remains deferred. |
| Isolated lab (Task 7) | **Retain** | The lab already contains testing; add an onboarding exercise for new external assessors. |
| Document library (Task 8) | **Modify** | Add D7 Standing Authorization and D8 Assessor Onboarding; D3 gains a "clock" block; D1 stays for new scopes. |
| Evaluation (Task 10) | **Retain / extend** | Same simulation, new "continuous" scenario. |

### 11.3 New and modified components

| ID | Component | Description | Integrates with |
|---|---|---|---|
| N1 | Standing Authorization Profile (replaces repeated D1 approvals) | One approval covers a fixed scope list and a named tester for up to 90 days. Renewal is automatic only if the scope list, tester and personal-data approval are unchanged and the tester has no overdue findings; otherwise a new full request (D1) is required. | Authorization workflow (renew_standing); register; disclosure layer (overdue findings block renewal) |
| N2 | Data-Protection Gate | Extra check on every Tier 2 request: synthetic-data-first rule, DPA verified for every external assessor, redaction check, and a 24-hour DPO notice of any personal-data finding. Adds 0.5 h to the review of personal-data cases. | Legal controls C-05 to C-10; D3 validation |
| N3 | Disclosure Clock | Shorter remediation windows: Critical 7 days, High 30, Medium 60, Low 90. Reminders at 50 % and 80 % of the window; automatic GB escalation when overdue. | D3 deadline field; can_disclose; log |
| N4 | Third-party Assessor Onboarding (D8) | Identity check, NDA, DPA, conduct attestation, tool allow-list and a lab onboarding exercise before the first authorization. | AV7; lab; D1 |

```
PROFILE_V1 = {"Critical": 30, "High": 60, "Medium": 90, "Low": 120}   # v1.0 - v1.2
PROFILE_V2 = {"Critical": 7,  "High": 30, "Medium": 60, "Low": 90}    # v2.0 (changed requirement)

def renew_standing(prev, new, today, overdue_findings=0): ...          # N1
```

With the new profile the same finding FND-LMS-001 (found 17 Nov 2026, High) now has deadline

| No. | Case | Expected | Result | Reason |
|---|---|---|---|---|
| S1 | Same scope, same tester, no overdue findings | AUTO_RENEW | AUTO_RENEW | OK |

**2026-12-17** instead of 2027-01-16, and on 18 Dec 2026 can_disclose returns **ESCALATE_GB**.

| No. | Case | Expected | Result | Reason |
|---|---|---|---|---|
| S2 | Scope widened to add SYS-17 (SSO) | NEW_FULL_REQUEST | NEW_FULL_REQUEST | SCOPE_CHANGED |
| S3 | Same scope but 1 overdue finding | BLOCKED | BLOCKED | OVERDUE_FINDINGS |
| S4 | Different tester named | NEW_FULL_REQUEST | NEW_FULL_REQUEST | TESTER_CHANGED |
| S5 | Standing period of 100 days | NEW_FULL_REQUEST | NEW_FULL_REQUEST | STANDING_AUTH_MAX_90_DAYS |

**Test of the new standing-authorization component (N1)**

## 11.4 Evaluation of the revised framework

The scenario is the large programme with continuous assessment: 90 requests and 90 findings per month. v1.2 treats every request as new. v2.0 treats 70 % as renewals under standing authorization (approved by the Department Authoriser, mean 0.25 h), applies the extra 0.5 h data-protection gate to personal-data cases, and uses a structured D3 plus a fourth coordinator (assumed triage mean 1.0 h). **These parameters are assumptions.**

| Measure | Refined v1.2 | Revised v2.0 |
|---|---|---|
| Median approval turnaround (h) | 1.2 | 0.3 |
| 90th percentile approval (h) | 8.6 | 2.7 |
| Approved within 40 h (%) | 99.96 | 99.99 |
| Median for personal-data/external cases (h) | 3.4 | 3.2 |
| Critical/High median notice (h) | 1.1 | 0.7 |
| Critical/High notified within 8 h (%) | 99.19 | 99.97 |

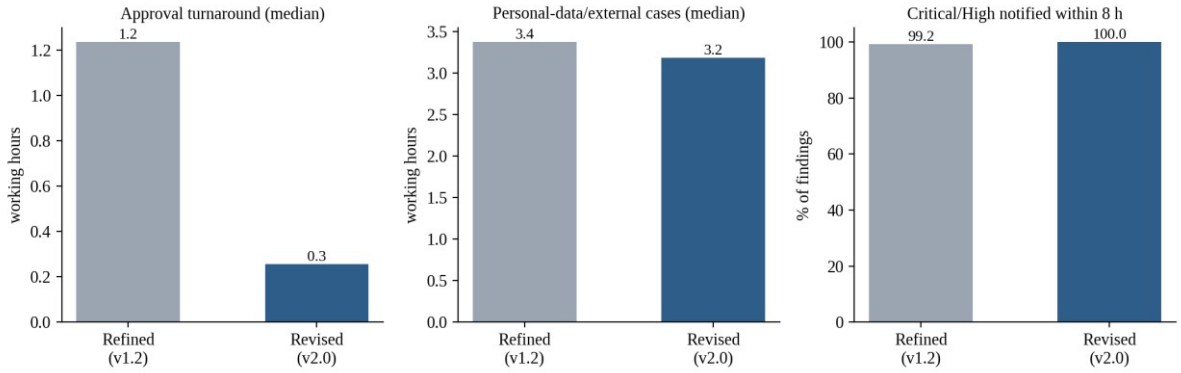



*Figure 4: Continuous-assessment scenario, refined v1.2 against revised v2.0*

The stricter data gate adds review time, yet the median for personal-data and external cases did not rise (3.4 h to 3.2 h), because standing authorizations remove most routine requests from the Board's queue. This is a result of the model and depends on the 70 % renewal share; if few requests were renewals, the gate would add queueing.

## 11.5 Defence of the final framework using evidence

| Claim | Evidence |
|---|---|
| Authorization cannot be bypassed | Walkthrough (Task 9.2) and tests T1, T4, L5 and S1–S5 show missing, expired or changed authorizations are rejected or sent back to a full request. |
| Scope stays contained | T2 and L14 reject a registered but out-of-scope system; scope guard in the lab (Task 7); standing scope is frozen (S2). |
| Law is respected and traceable | Task 4 maps 11 requirements to 12 controls; the personal-data decision in 4.5 applies DPDP duties early, so the 13 May 2027 date needs no redesign. |
| Disclosure is fast but safe | Window of 7 days for Critical (N3); T5 shows that overdue personal-data findings go to the GB and never become public; 99.97 % of Critical/High notices go out within 8 h in the model. |
| It scales | Task 10: large baseline met the SLA for only 64.73 % of requests; refined design 99.96 %; v2.0 holds under continuous load (99.99 %). |
| It is easy to extend | The changed requirement needed one redesigned component (the authorization workflow), five modified components and four new components; the lab, classification and evaluation were retained. Adding the new profile changed one data table (PROFILE_V2). |

**Final check against the design criteria of Task 1**

| Criterion | Result | Source |
|---|---|---|

| | | |
|---|---|---|
| DC1 Authorization completeness | Met: T1, L5 reject blank sign-off | Task 9 |
| DC2 Scope containment | Met: T2, L6, L14 reject out-of-scope assets | Tasks 8, 9 |
| **Criterion** | **Result** | **Source** |
| DC3 Legal traceability | Met: 11 of 11 requirements linked to controls | Task 4 |
| DC4 Personal-data protection | Met: L13 rejects un-redacted evidence; T5 blocks public release | Tasks 8, 9 |
| DC5 Timeliness at scale | Met after refinement: 99.96 % within 40 h (baseline 64.73 %) | Task 10 |
| DC6 Disclosure safety | Met in the model: 99.97 % within 8 h; no automatic public release | Tasks 9–11 |
| DC7 Extensibility | Met: change confined to authorization workflow, data tables and the document library | Task 11 |

## 11.6 Remaining trade-offs and limitations, with future improvements

| **Trade-off or limitation** | **Why it remains** | **Proposed improvement** |
|---|---|---|
| Standing authorizations reduce per-engagement scrutiny and can become stale. | Speed for continuous work comes from not re-reviewing each cycle; the 90-day limit, frozen scope and overduefinding block reduce but do not remove the risk. | Add a quarterly random audit of renewals and automatic expiry reminders to System Owners. |
| The stricter data gate depends on a few DPO staff. | Tier 2 cases still need human review; a surge of external assessors could queue. | Train DPO deputies and preapprove standard data-handling patterns (templates) to reduce case-by-case review. |
| Results come from a model with assumed parameters. | The programme has no real operating data yet. | Collect actual turnaround and notice times for one quarter, rerun sim.py with measured values and adjust tiers. |
| Lab findings may not match production. | Testing is confined to a lab by design, so production exposure must be confirmed separately (F6). | Add a read-only configuration comparison between lab replica and production to D3. |

| | | |
|---|---|---|
| Legal position is a snapshot. | DPDP duties begin on 13 May 2027 and interpretation will develop; counsel has not reviewed this mapping. | Schedule a legal review on 13 May 2027 and after any DPDP guidance; add a bug-bounty option only when legal safeharbour terms exist. |
| Shorter windows may push owners to rushed patches. | A 7-day window for Critical is demanding for production systems. | Allow interim mitigation to satisfy the clock, with a separate date for the permanent fix. |

**Conclusion.** UASAP-EF answers all seven enquiry questions, satisfies the seven design criteria in its final form and adapts to continuous and third-party assessment by redesigning one component, modifying five and adding four, without discarding the earlier design.

**Evidence delivered for Task 11:** revised framework (11.2, 11.3), demonstrated adaptation with tests and simulation (11.3, 11.4), evidence-based defence (11.5), explicit trade-offs and improvements (11.6).

## APPENDIX A – Reference program (core rules)

The full program is supplied as **framework.py** (rules, tests, walkthrough) and **sim.py** (Task 10 and 11 simulation); **diagrams.py** draws Figures 1 and 2. Running **python3 framework.py** prints all test results; **python3 sim.py** prints the evaluation tables and redraws Figures 3 and 4. The core rules are reproduced here.

```
def validate_auth(f, today, fixes=()):
for k in REQ_AUTH:
    missing = blank(f.get(k)) if "F1" in fixes else (k not in f)    # F1: empty value = missing
if missing:
        return "REJECT", "MISSING_FIELD:" + k
if f["end"] <= f["start"]:
    return "REJECT", "BAD_DATES"          if
(f["end"] - f["start"]).days + 1 > MAX_DAYS:
    return "REJECT", "TOO_LONG"
if f["start"] < today:
    return "REJECT",
"BACKDATED"    for s in
f["scope_ids"]:      if s not in
REGISTER:
        return "REJECT", "UNKNOWN_SCOPE:" + s    if
has_pd(f["scope_ids"]) and not f.get("dpo_approved"):
    return "HOLD", "DPO_REVIEW"
  if "F3" in fixes and f["tester_type"] == "external":              # F3: legal conflict check
if not f.get("nda_signed"):
        return "HOLD", "NDA_REQUIRED"            if
has_pd(f["scope_ids"]) and not f.get("dpa_signed"):
        return    "HOLD",    "DPA_REQUIRED"
return "APPROVED", "OK"
```

```
def validate_finding(fd, auth, fixes=(), profile=PROFILE_V1):
  for k in ["finding_id", "engagement_id", "asset_id", "title", "severity", "cvss",
"found_on", "evidence_redacted"]:      if blank(fd.get(k)) and fd.get(k) is not False:
        return "REJECT", "MISSING_FIELD:" + k,
None    a = fd["asset_id"]    if a not in REGISTER:
    return "REJECT", "UNKNOWN_ASSET", None
  if "F2" in fixes and a not in auth["scope_ids"]:                  # F2: scope guard on findings
return "REJECT", "OUT_OF_SCOPE_ASSET", None
  if "F4" in fixes and not (auth["start"] <= fd["found_on"] <= auth["end"]):  # F4: authorization
window
    return "REJECT", "OUTSIDE_AUTH_WINDOW",
None    if not (0.0 <= fd["cvss"] <= 10.0):      return
"REJECT", "CVSS_RANGE", None    if band(fd["cvss"]) !=
fd["severity"]:
```

```
        return "REJECT", "SEVERITY_MISMATCH",
None     pd = REGISTER[a][2]     if pd and not
fd["evidence_redacted"]:
        return    "REJECT",    "UNREDACTED_PERSONAL_DATA",    None
days = profile.get(fd["severity"])
    rec = {"finding_id": fd["finding_id"], "engagement_id": fd["engagement_id"], "asset_id": a,
           "severity": fd["severity"], "cvss": fd["cvss"], "personal_data": pd,
           "found_on": fd["found_on"].isoformat(),
           "notify_dpo_by": (fd["found_on"] + timedelta(days=1)).isoformat() if pd else None,
           "deadline": (fd["found_on"] + timedelta(days=days)).isoformat() if days else None,
           "track": "COORDINATED"}
    return "ACCEPT", "OK", rec
```

```
def can_disclose(rec, today, status, owner_ack=True, exploited=False, fixes=()):
if status == "REMEDIATED":
        return "DISCLOSE_SUMMARY"                    # redacted summary after the fix
if rec["deadline"] is None or today <= date.fromisoformat(rec["deadline"]):
        return "WAIT"
    # window has expired and the finding is still open
if "F5" not in fixes:
        return "PUBLIC_DISCLOSURE"                   # baseline behaviour (unsafe)
if rec["personal_data"]:
        return "ESCALATE_GB"                         # personal data is never made public
if exploited and not owner_ack:
        return "FULL_DISCLOSURE_REVIEW"              # GB decides; never automatic    return
"ESCALATE_GB"
```

```
def  renew_standing(prev,  new,  today,  overdue_findings=0):          if  (new["start"]  -
prev["start"]).days > 90 or (new["end"] - new["start"]).days + 1 > 90:
        return   "NEW_FULL_REQUEST",   "STANDING_AUTH_MAX_90_DAYS"
if set(new["scope_ids"]) != set(prev["scope_ids"]):
        return   "NEW_FULL_REQUEST",   "SCOPE_CHANGED"
if has_pd(new["scope_ids"]) and not prev.get("dpo_approved"):
        return   "NEW_FULL_REQUEST",   "PERSONAL_DATA_NOT_PRE_APPROVED"
if new["tester"] != prev["tester"]:
        return   "NEW_FULL_REQUEST",   "TESTER_CHANGED"
if overdue_findings > 0:
        return     "BLOCKED",     "OVERDUE_FINDINGS"
return "AUTO_RENEW", "OK"
```

## APPENDIX B – References

1. Information Technology Act, 2000 (India), ss. 43, 43A, 46, 66, 66B, 66C, 70B, 72, 72A, 75; CERT-In Directions under s. 70B(6), 28 April 2022.
2. Digital Personal Data Protection Act, 2023, ss. 8, 44 and Schedule; Digital Personal Data Protection Rules, 2025, notified 13–14 November 2025 with phased commencement (13 November 2025, 13 November 2026, 13 May 2027).
3. Computer Fraud and Abuse Act, 18 U.S.C. § 1030; Van Buren v. United States, 593 U.S. 374 (2021); US Department of Justice charging policy on good-faith security research, May 2022.
4. NIST SP 800-115, Technical Guide to Information Security Testing and Assessment (2008).
5. ISO/IEC 29147 (vulnerability disclosure) and ISO/IEC 30111 (vulnerability handling processes).
6. FIRST, Common Vulnerability Scoring System (CVSS) specification.
7. Oracle VirtualBox User Manual, chapters on host-only and NAT networking.